Security Incident Response Plan

Document ID	SEC-010
Department	IT and Information Security
Document type	Plan
Owner	Chief Information Security Officer
Version	2.1
Status	APPROVED
Effective / last reviewed	2025-10-03
Audience	All employees and contractors
Related documents	ENG-004, SEC-014, SEC-015, CS-005

Summary. The Northstar Systems plan for detecting, triaging, containing, eradicating, recovering from and reviewing security incidents, covering severities, the Security Incident Response Team, reporting channels, customer and regulatory notification, evidence handling and exercises.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This plan describes how Northstar Systems Private Limited responds to information security incidents. It exists so that every suspected incident is reported quickly, assessed consistently, contained before it spreads, and reviewed so that the same weakness does not recur. It defines who does what, how severity is decided, what must be communicated to customers, regulators and employees, and how evidence is preserved.

The plan applies to all employees and contractors and to all company systems and data, including the Northstar Nexus Platform, Nexus Connect, Nexus Insight, corporate systems such as NorthPeople, NorthPay and NorthBuy, endpoints managed by NorthGuard, and third-party services that process company data. It covers confirmed incidents and suspected events such as phishing, malware, account compromise, lost devices, data leaks, insider misuse, denial-of-service attacks and vendor breaches.

Service-availability incidents without a security element follow the engineering incident process in ENG-004. Where an event is both, for example a ransomware attack that takes down the Nexus Platform, both processes run together under one Incident Commander. Customer-facing communication follows CS-005, evidence and log handling follows SEC-014, and monitoring is governed by SEC-015.

Any legal or regulatory reference in this plan is illustrative and must be verified by Legal before external use.

2. Definitions

- **Security event**: an observable occurrence that may indicate a policy violation or security failure, such as an unusual login alert.
- **Security incident**: an event confirmed or reasonably suspected to compromise the confidentiality, integrity or availability of company or customer information or systems.

- **SIRT (Security Incident Response Team)**: the cross-functional team that manages incidents, led by the Incident Response Lead (the CISO delegate).
- **Incident Response Lead**: the CISO delegate who directs triage, containment and recovery for a security incident.
- **Incident Commander (IC)**: the person who coordinates a SEV1 or SEV2 response; for security incidents the IC is normally the Incident Response Lead.
- **Containment**: actions that stop an incident from spreading, such as isolating a host or disabling an account.
- **Indicators of compromise (IOC)**: observable artefacts, such as IP addresses or file hashes, that suggest a compromise.
- **Privacy Officer**: reports to the General Counsel and decides personal-data breach notifications.

3. Roles and Responsibilities

Role	Responsibility during an incident
Every employee and contractor	Report suspicions immediately to the Security Desk
Security Desk	Receives reports 24x7, logs the case, performs first assessment
Incident Response Lead	Leads SIRT, assigns severity, directs containment and recovery
CISO	Executive owner, informs CEO and board, approves major decisions
Security Operations analysts	Investigate alerts in NorthWatch, collect evidence, apply containment
IT Operations	Isolates devices, resets accounts, restores systems
Engineering (on-call manager)	Fixes affected services, supports forensic access
Communications Lead	Prepares customer and employee messages
Legal and General Counsel	Advises on contractual and regulatory duties
Privacy Officer	Decides on personal-data breach notification
HR	Handles insider cases and employee communication
Customer Success	Contacts affected customers using approved templates
Scribe	Records timeline and decisions

4. Reporting a Suspected Incident

Anyone who suspects an incident must report it to the Security Desk immediately. Do not wait to be sure, do not investigate on your own, and do not delete anything.

- Phone: Security Desk hotline ext. 5555 (24x7).
- Email: security@northstar-systems.example.
- Phishing emails: use the Report Phish button in the mail client.
- Lost or stolen device: report to the Security Desk within 1 hour of discovery.
- Suspected exposure of a secret or key: report at once; see SEC-008.

Examples of reportable events: a laptop that is lost, a clicked phishing link, a request for a password by phone, unfamiliar MFA prompts, a customer who says they received data that is not theirs, a repository that contains a credential, and a vendor who tells Northstar about a breach.

Reporting in good faith is never punished, even when the report involves the reporter's own mistake. Retaliation against a reporter is a disciplinary matter.

5. Severity Classification

Security incidents are classified into four levels. Critical aligns with engineering SEV1.

Level	Description	Examples	Initial response
Critical	Confirmed breach of customer data or production, widespread outage by attack, ransomware, loss of signing keys	Customer production data exfiltrated; ransomware on Tier-1 systems	Incident Response Lead engaged immediately; SEV1 process; acknowledge within 5 minutes
High	Compromise of privileged account, malware on multiple systems, exposure of Restricted data without confirmed misuse	Admin credential stolen; production secret in a public repository	SIRT activated; acknowledge within 15 minutes
Medium	Single endpoint infection, contained phishing success, policy breach with limited data	One laptop with malware, no lateral movement	Handled by Security Operations; same business day
Low	Unsuccessful attacks, low-risk policy violations	Blocked phishing, a failed brute-force attempt	Logged and trended; next business day

Severity may be raised or lowered as facts emerge, and the Incident Response Lead records every change and the reason. When in doubt, classify higher. Critical incidents also meet the SEV1 definition, so the SEV1 timings apply: status updates every 30 minutes and customer-facing updates on Northstar Status within 30 minutes of declaring a SEV1 or SEV2.

6. Response Phases

6.1 Detect

Incidents are detected through NorthWatch alerts, endpoint alerts from NorthGuard, user reports, customer reports, vendor notifications, threat intelligence and weekly log review. Security Operations investigates alerts and decides whether a security event becomes an incident.

6.2 Triage

The Security Desk or analyst opens an incident record in NorthDesk and checks: what was affected, what data is involved, whether the activity is still happening, whether customers are affected, and whether Restricted data is involved. The Incident Response Lead assigns a severity and the roles needed. A scribe starts the timeline with UTC and IST timestamps.

6.3 Contain

Containment aims to stop harm quickly while preserving evidence. Typical actions are:

1 Isolate the affected endpoint from the network through NorthGuard.
2 Disable or reset compromised accounts in NorthID and revoke active sessions and tokens.
3 Rotate exposed secrets and keys in NorthVault or the cloud KMS.
4 Block malicious IP addresses or domains at the firewall or WAF.
5 Remote wipe of a lost or stolen device within 4 hours of confirmed loss.

6 In production, restrict access to NorthGate and take Tier-1 services to a safe state only on Incident Commander approval.

Short-term containment must not destroy evidence. Where possible, take a forensic image or snapshot before reimaging.

6.4 Eradicate

Remove the root cause: delete malware, close the vulnerable path, patch systems, remove malicious accounts or persistence, and confirm through scans that indicators of compromise are gone. Vulnerabilities involved are fixed under the vulnerability SLAs: Critical within 72 hours, High within 14 days, Medium 30 days and Low 90 days; actively exploited vulnerabilities must be mitigated within 24 hours.

6.5 Recover

Restore systems from known-good builds or backups, validate integrity, return services to production in stages and monitor intensively for recurrence. Recovery for production services follows the RTO and RPO for the service tier in ENG-014. IT Operations and Engineering confirm health before the Incident Commander closes the response.

6.6 Review

A blameless post-incident review is held within 5 business days of resolution for Critical and High incidents. It covers the timeline, root cause, what worked, what did not, and actions with owners and due dates tracked in NorthDesk. High audit-related findings are remediated within 60 days. The CISO receives a summary for Critical and High incidents. Lessons are fed into training, detection rules and this plan.

7. Communication

7.1 Internal communication

The Incident Response Lead decides who is told, on a need-to-know basis. During a Critical incident, the CISO informs the CEO, COO and General Counsel without delay. Employees are informed through an approved channel when they must take action, for example a password reset. Rumour, personal social media and unapproved chat channels must not be used for incident details.

7.2 Customers

A confirmed breach affecting a customer's data must be notified to that customer within 72 hours of confirmation, which is a contractual commitment. The Communications Lead and Customer Success prepare messages using approved templates from the communication library. The first customer notification for a SEV1 or SEV2 goes out within 30 minutes of declaration through Northstar Status and by email to affected Enterprise and Premier contacts. No message may contain internal system names, personal data or promised delivery dates that Engineering has not confirmed. A customer-facing root cause analysis is provided to Enterprise and Premier customers within 5 business days of resolution; Standard customers may request it within 10 business days. Tone must be plain, empathetic and blameless.

7.3 Regulators and law enforcement

Notifications to authorities are decided by Legal and the Privacy Officer. For example, a rule requiring reporting of specified incident types within 6 hours (CERT-In style, illustrative) may apply; it must be verified by Legal before relying on it. The Privacy Officer decides personal-data breach notifications and whether affected individuals must be told. Employees must not contact regulators, police or the media on behalf of Northstar unless Legal directs.

7.4 Third parties

If an incident originates with a vendor, the vendor owner in Procurement and GRC engage the vendor and request its incident report. Contracts and DPAs define the vendor's notification duties; see SEC-011.

8. Evidence Handling and Forensics

Evidence must be collected and stored so that it remains trustworthy. Security Operations keeps a chain-of-custody record that lists who collected each item, when, from where, and how it was stored. Forensic evidence is preserved for 12 months. Security audit logs are retained 24 months in tamper-evident storage. Where Legal declares a legal hold, retention is suspended until the hold is released, even for logs normally deleted earlier.

Forensic copies are made read-only, hashed with SHA-256 and kept in restricted storage. Employees must not power down or wipe a suspect machine unless the Incident Response Lead directs it. External forensic firms may be engaged by the CISO with Legal's approval under privilege.

9. Special Scenarios

9.1 Phishing

A user who receives a suspicious email uses the Report Phish button. Security Operations removes the message from all mailboxes and blocks the sender. If the user clicked a link or entered credentials, they must call ext. 5555 right away; their sessions are revoked and their password reset. Phishing simulations run quarterly, and an employee who fails 3 simulations in 12 months receives mandatory retraining and a manager conversation.

9.2 Lost or stolen device

The user reports to the Security Desk within 1 hour of discovery and to the IT Service Desk within 24 hours. NorthGuard attempts remote wipe within 4 hours of confirmed loss. Full-disk encryption reduces the risk of data exposure, but the Security Desk still checks what data and sessions were on the device.

9.3 Ransomware

The first priority is isolation: disconnect affected systems, preserve evidence, protect backups and notify the CISO. Northstar does not decide on paying a ransom without the CEO, CISO and General Counsel agreeing, and law enforcement advice is considered. Recovery uses clean backups from the secondary region Hyderabad.

9.4 Insider threat

Cases involving employees or contractors are managed by the Incident Response Lead with HR and Legal. Monitoring beyond normal practice requires written approval from the General Counsel

and the Chief People Officer under SEC-015.

9.5 Compromised credentials or secrets

Reset the credential, revoke sessions and tokens, search NorthWatch logs for use since exposure, and rotate related secrets. Treat a secret found in source code as compromised even if the repository is private.

10. Worked Examples

Example 1: A Support Lead reports on a Friday evening that a customer's data appeared in another customer's NorthAssist ticket. The Security Desk opens a case and the Incident Response Lead classifies it as Critical, because customer data was exposed to another customer. The SEV1 process starts, the affected view is disabled, evidence is preserved and the customer's account owner is informed. The breach is confirmed at 21:00 on Friday, so the contractual 72-hour customer notification deadline ends at 21:00 on Monday. The Privacy Officer decides the personal-data notification route.

Example 2: A finance analyst in Mumbai clicks a link in a fake invoice email and enters her NorthID password. She calls ext. 5555 within five minutes. Security Operations revokes her sessions, resets her password, checks NorthWatch for sign-ins from unknown addresses, finds none and classifies the event as Medium. She repeats the training module in NorthLearn.

Example 3: A developer pushes a production API key to a public repository. A scanner flags it within 20 minutes. The key is revoked and replaced, logs are checked for use and the repository is made private. The incident is High because Restricted data could have been accessed, and no evidence of misuse is found.

11. Testing, Training and Metrics

The plan is exercised at least once a year with a tabletop exercise that includes SIRT, Engineering, Customer Success, Legal and Communications. Ransomware and customer-data-breach scenarios are rotated. New joiners complete security awareness training within 14 days of joining, with an annual refresher. SIRT members train on forensic tools and the communication library. Metrics reported to the CISO quarterly include time to acknowledge, time to contain, number of incidents by severity, phishing report rate and action-item closure rate.

12. Frequently Asked Questions

- **Should I report something even if I am not sure it is an incident?** Yes. Report immediately to ext. 5555 or security@northstar-systems.example. A false alarm costs little; a late report can cost a great deal.
- **Who leads the response?** The Incident Response Lead, who is the CISO delegate, leads the SIRT.
- **What are the response phases?** Detect, triage, contain, eradicate, recover and review.
- **How long do we keep forensic evidence?** 12 months, unless a legal hold extends it.
- **Can I tell a customer about an incident myself?** No. Customer messages are prepared by the Communications Lead and Customer Success from approved templates, and may not promise dates Engineering has not confirmed.
- **What if the incident happens at night or on a holiday?** The Security Desk hotline is staffed 24x7 and the Critical and High paths page the Incident Response Lead outside business hours.

- **What happens to a reporter who made the mistake?** Good-faith reports are not punished. Repeated carelessness is handled under the disciplinary process, not under this plan.

13. Exceptions and Escalation

Deviations from this plan during a live incident are allowed only when the Incident Response Lead records the reason, for example skipping a step to stop active data loss. Disagreements between Engineering and Security about containment are escalated to the CISO and the CTO. Questions about the plan go to the Security Desk. The Incident Response Lead may escalate to the CEO at any time.

14. Related Documents

See ENG-004 for the engineering incident process, SEC-014 for audit logging, SEC-015 for monitoring, CS-005 for customer communication, SEC-008 for key compromise and SEC-011 for vendor incidents.

15. Revision History

Version	Date	Change
1.0	2024-02-12	Initial plan
2.0	2025-02-20	Added four severity levels and ransomware scenario
2.1	2025-10-03	Clarified 72-hour customer notification and evidence retention